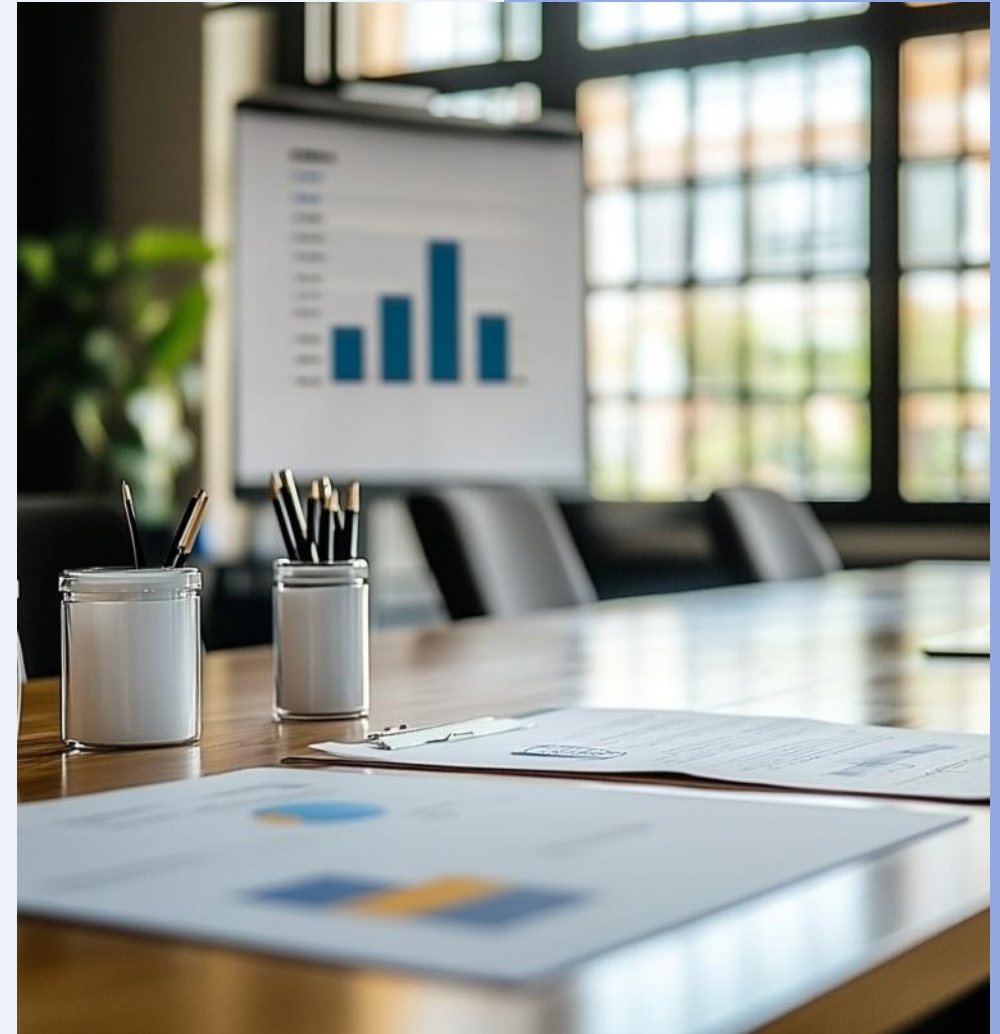


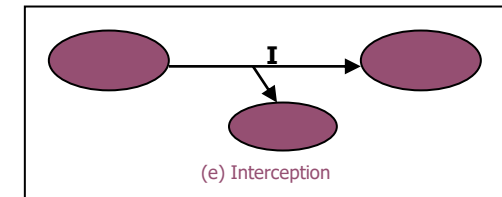
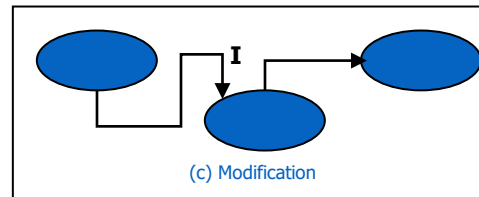
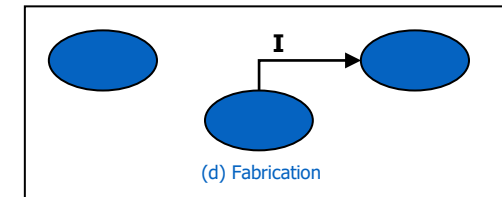
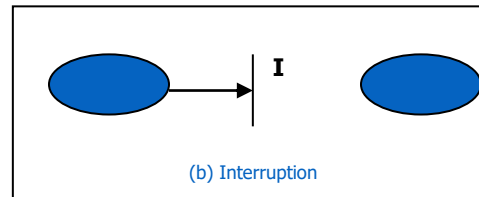
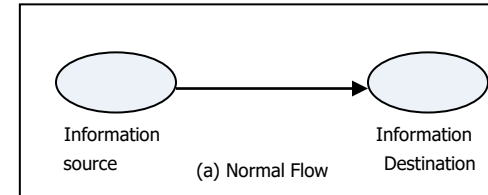
RFC 2828

Cybersecurity Threats

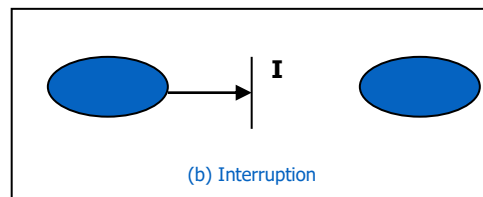
Topic 3



Type Of Attacks



Type Of Attacks



Interruption - הפרעה/השבתה (זמינות)

פגיעה ברציפות שירות/משאב כך שאינו מגיב או מגיב באיחור חריג.

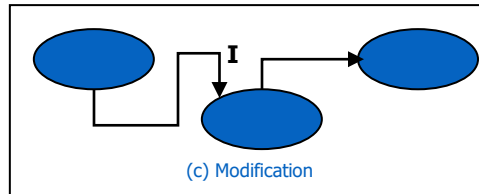
- **LLM** - הצפת Endpoint בשאלות, או ניצול מלא של GPU/CPU,

השהיית תורים.

- **ענן** - DDoS על ה-load balancer.



Type Of Attacks



Modification - שינוי/שיבוש (שלמות)

שינוי לא מורשה של נתונים/מודלים/תצורה/קוד בדרך או במנוחה.

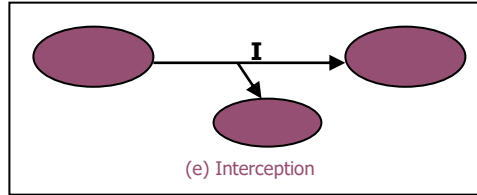
LLM

- Data/Model poisoning שינוי קבצי אימון או החלפת checkpoint ב-registry
- Prompt/Context injection ב- מסמך זדוני משנה הוראות בזמן שאלתת איחזור.

ענן שינוי Policy/IAM (over-privilege)



Type Of Attacks



Interception יירוט/האזנה (סודיות)

גישה לא מורשית לתוכן/מטא-דאטה בזמן מעבר או במנוחה ללא שינוי גלוי.

• LLM

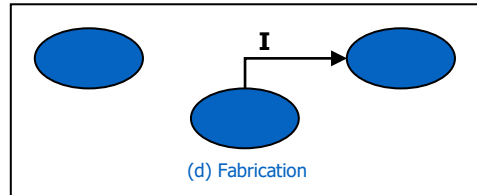
יירוט prompts/contexts/logs דרך פרוקסי, Telemetry לא מוקשחים; שמירת outputs לא מוצפנים.

• ענן

אחזור אובייקטים מבאקט ציבורי/מפתח דלוף; sniffing בין מיקרו-שירותים



Type Of Attacks



Fabrication זיוף/המצאה (אותנטיקציה/נאותות)

יצירת נתונים/אירועים/זהויות שלא התקיימו והכנסתם כגורם לגיטימי.

• LLM

- התחזות לשירות LLM באמצעות API key גנוב והפקת תשובות בשם המערכת.
- Agent tool-command injection - יצירת פעולות מערכת שלא נדרשו.

• ענן

- יצירת "service account/keys" והפעלת משאבים (למשל כריית קריפטו). פרסום image בשם פרויקט אמיתי.



Cyber Attack Classifications



Active Attack

01

In active attacks, the attacker attempts to modify system resources or disrupt operations, potentially leading to data breaches or system malfunctions requiring immediate security measures.

Passive Attack

02

Passive attacks focus on gathering information without affecting system resources, such as eavesdropping on communications, which can lead to unauthorized access to sensitive information.

Hybrid Attack

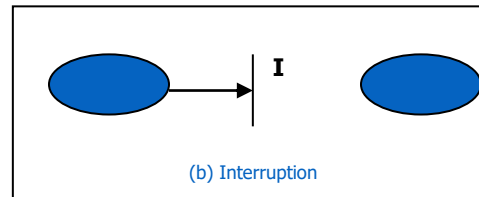
03

A hybrid attack combines elements of both active and passive attacks, allowing attackers to Act system vulnerabilities while remaining undetected, increasing the risk of data compromise.

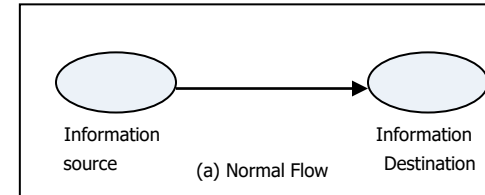
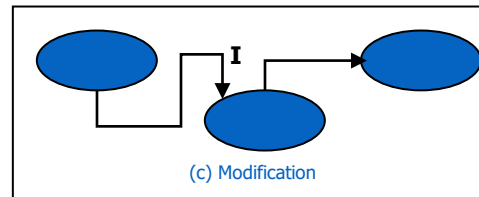
Type Of Attacks



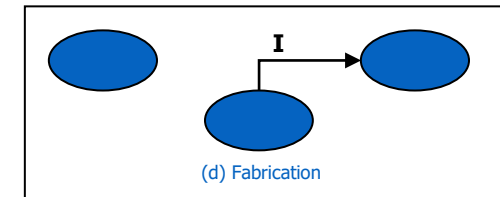
Passive threats



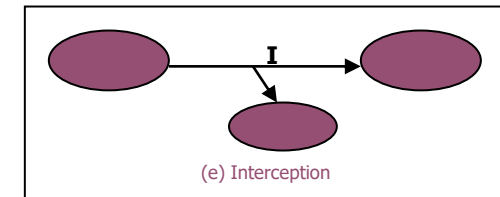
Active threats



Active threats



Active threats



RFC 2828

RFC 2828 describes four kinds of threat consequences and kinds of attacks that result:

1. Unauthorized disclosure **גלוי**

- חשיפה** 1. Exposure
- יירוט** 2. Interception
- הסקה** 3. Inference
- התערבות** 4. Intrusion

3. Disruption **שיבוש**

- שלילת יכולת** 1. Incapacitation
- השחתה** 2. Corruption
- חסימה** 3. Obstruction

2. Deception **הונאה**

- 1. Masquerade **התחזות**
- 2. Falsification **זיוף**
- 3. Repudiation **דחייה**

4. Usurpation **תפיסה בלתי**

- 1. Misappropriation **ניכוס פסול**
- 2. Misuse **שימוש לרעה**



RFC 2828

RFC 2828 describes four kinds of threat consequences and kinds of attacks that result:

1. Unauthorized disclosure גלוי

- חשיפה 1. Exposure
- יירוט 2. Interception
- הסקה 3. Inference
- התערבות 4. Intrusion

3. Disruption שיבוש

- שלילת יכולת 1. Incapacitation
- השחתה 2. Corruption
- חסימה 3. Obstruction

2. Deception הונאה

- 1. Masquerade התחזות
- 2. Falsification זיוף
- 3. Repudiation דחייה

4. Usurpation תפיסה בלתי

- 1. Misappropriation ניכוס פסול
- 2. Misuse שימוש לרעה



1) Unauthorized Disclosure

גלוי

1.8.1 UNAUTHORIZED DISCLOSURE:

Is a threat to confidentiality, it results in various attacks like:

חשיפה

1. Exposure: Sensitive data is directly released to an unauthorized entity.

יירוט

2. Interception: An unauthorized entity directly accesses sensitive data in transit.

הסקה

3. Inference: an unauthorized entity indirectly accesses sensitive data.

התערבות

4. Intrusion: An unauthorized entity circumvents system's security protections.



Exposure תשיפה



Problem 1

Misdirected emails compromise sensitive customer information unexpectedly

Unauthorized recipients gain access to data

Potential legal implications arise from disclosures

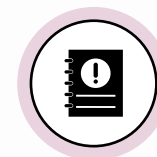


Problem 2

Public S3 bucket exposes company files to the general public

Sensitive data readily available to anyone online

Unauthorized parties can use the data maliciously



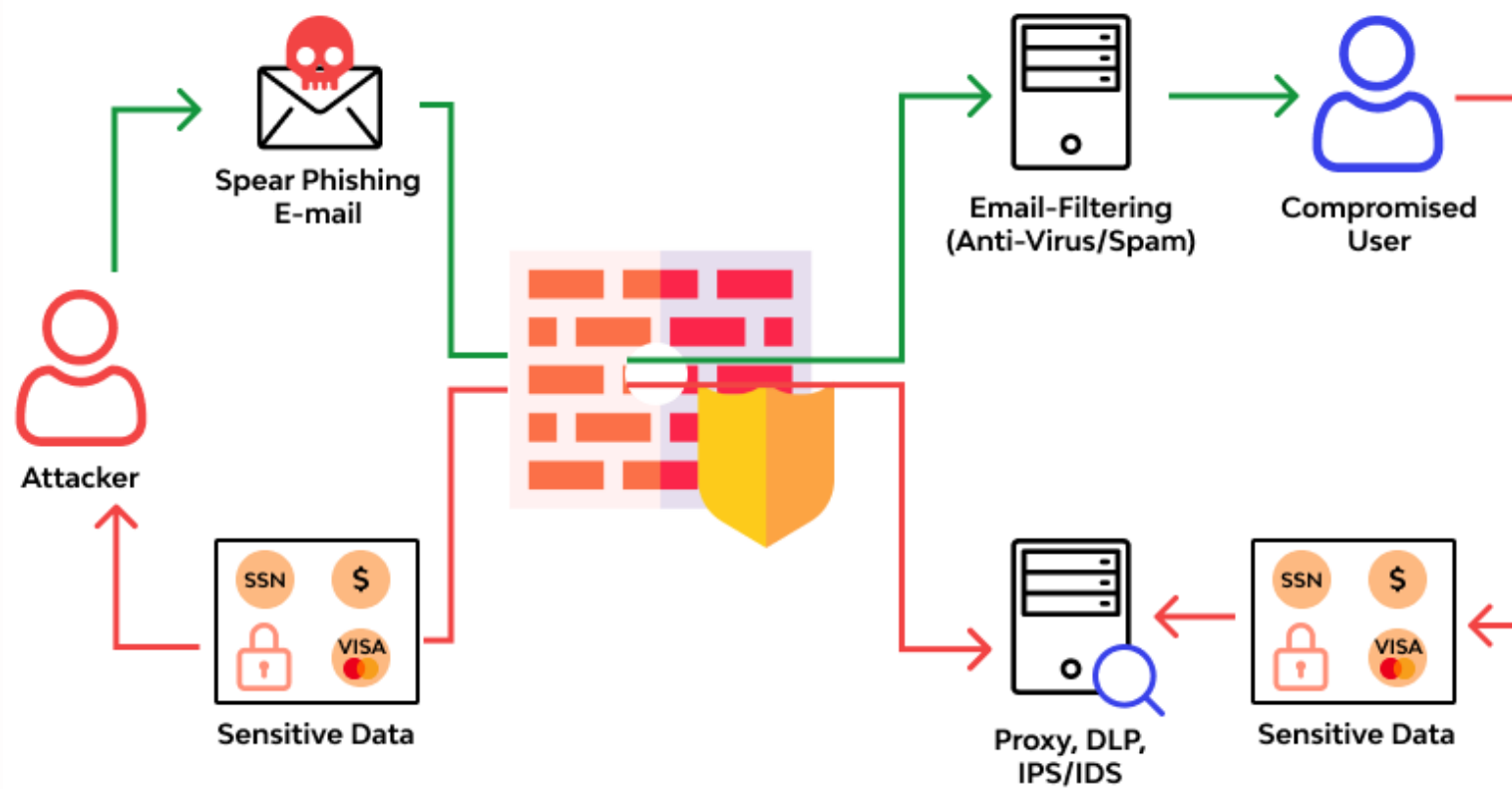
Problem 3

Shared links without authentication can leak confidential documents easily.

Links can be accessed by unintended individuals

Data leaks may harm a company's reputation significantly.

Exposure תשיפה



Exposure השיפה

1) Cloud Object Storage Exposure (Public Bucket Leak)

- Initial: Misconfigured bucket allows public list/get
- Act: Crawl & exfiltrate backups / PII / model checkpoints
- Impact: Data privacy breach, IP loss
- Mitigate:
 - Block Public Access org-wide; policy-as-code controls
 - Automated scanners (DLP, IaC checks), least-privilege

2) Web Error Logs Leak LLM Prompts & Secrets

- Initial: Verbose error pages / log aggregation without redaction
- Act: Scrape logs for prompts, API keys, and dataset paths
- Impact: Secret exposure, data leakage, prompt/IP theft
- Mitigate:
 - Structured logging with redaction; secrets never logged
 - Short retention; access controls; token scopes/rotation

Interception יירוט



01

Open Wi-Fi

Data can be easily intercepted on unsecured public networks.

03

Weak Ciphers

Outdated encryption algorithms can be broken, revealing confidential data.

02

Missing TLS

Without encryption, sensitive information is vulnerable during transmission.

04

HTTP Passwords

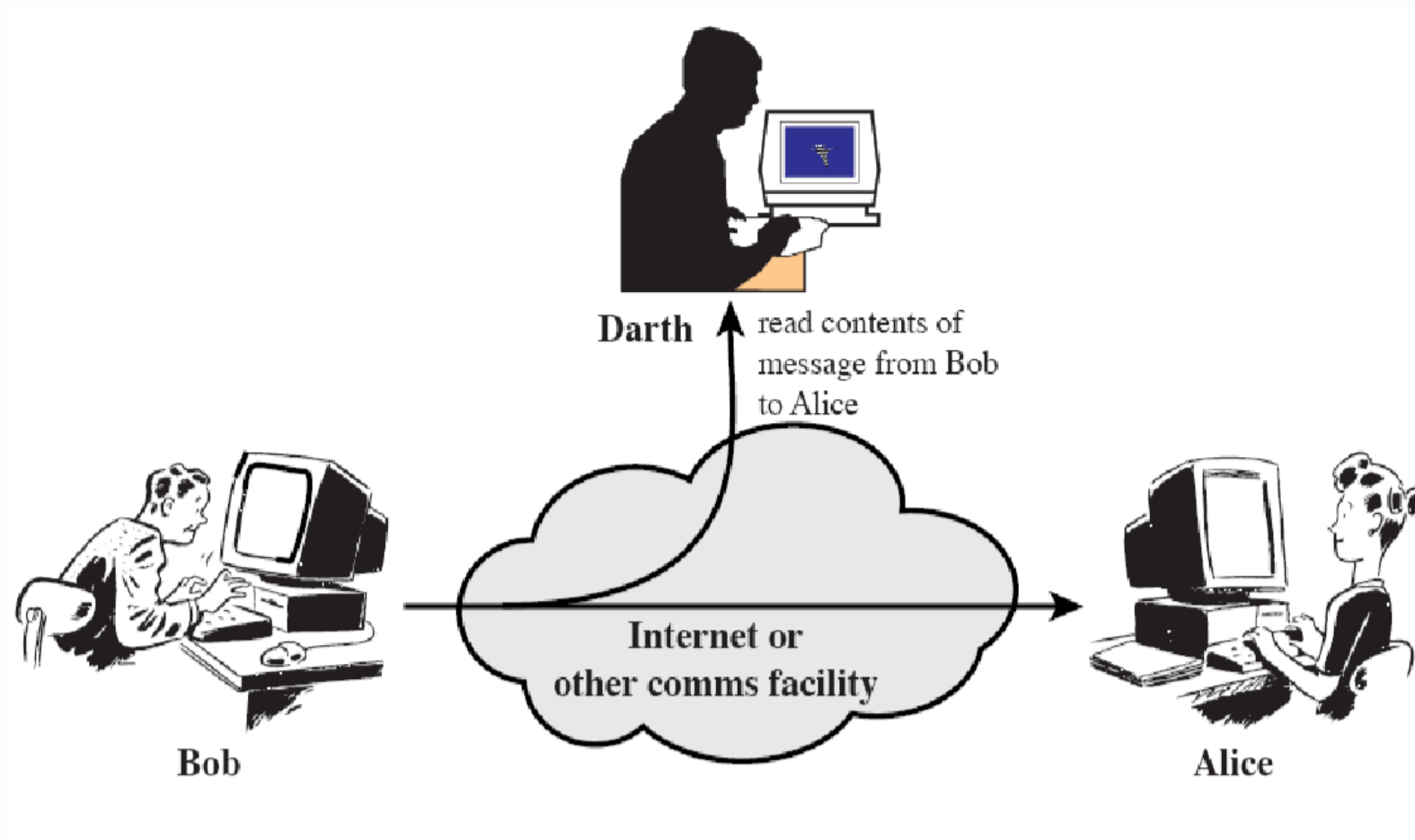
Using nonsecure protocols exposes usernames and passwords to attackers.

05

Packet Sniffing

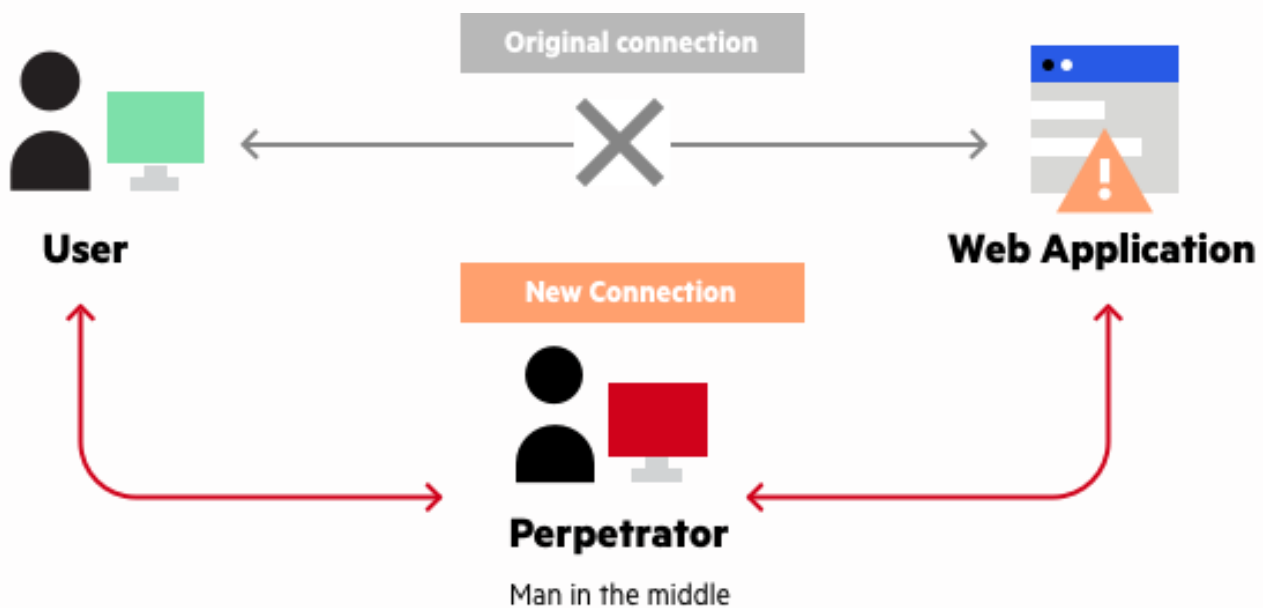
Attackers can capture unprotected network traffic to gain sensitive insights.

Interception יירוט



Interception יירוט

Man in the middle (MITM) attack



Interception יירוט

1) mTLS Missing on Model Serving (MITM on Inference)

- Initial: TLS termination misconfigured between gateway ↔ model pods
- Act: Sniff/alter inference payloads on east–west traffic
- Impact: PII exposure; response manipulation
- Mitigate:
 - mTLS service mesh; certificate rotation & pinning
 - Encrypt in-transit everywhere; strict network policies

2) WebSocket Sniffing/Injection on Real-Time AI Agent

- Initial: Agent UI uses ws:// without auth
- Act: Intercept/modify tool calls and function payloads
- Impact: Data exfiltration; unauthorized actions
- Mitigate:
 - wss:// with auth tokens; origin checks; message signing
 - Content security policies; per-action authorization

Inference

01

Metadata Leak

Extra data from files can expose sensitive information about individuals when accessed improperly.

02

Dashboard Risk

Overly granular dashboards may inadvertently reveal excessive information about user behavior or system status.

03

Query Leak

Query result sizes can leak information about database size and contents, exposing business logic.

04

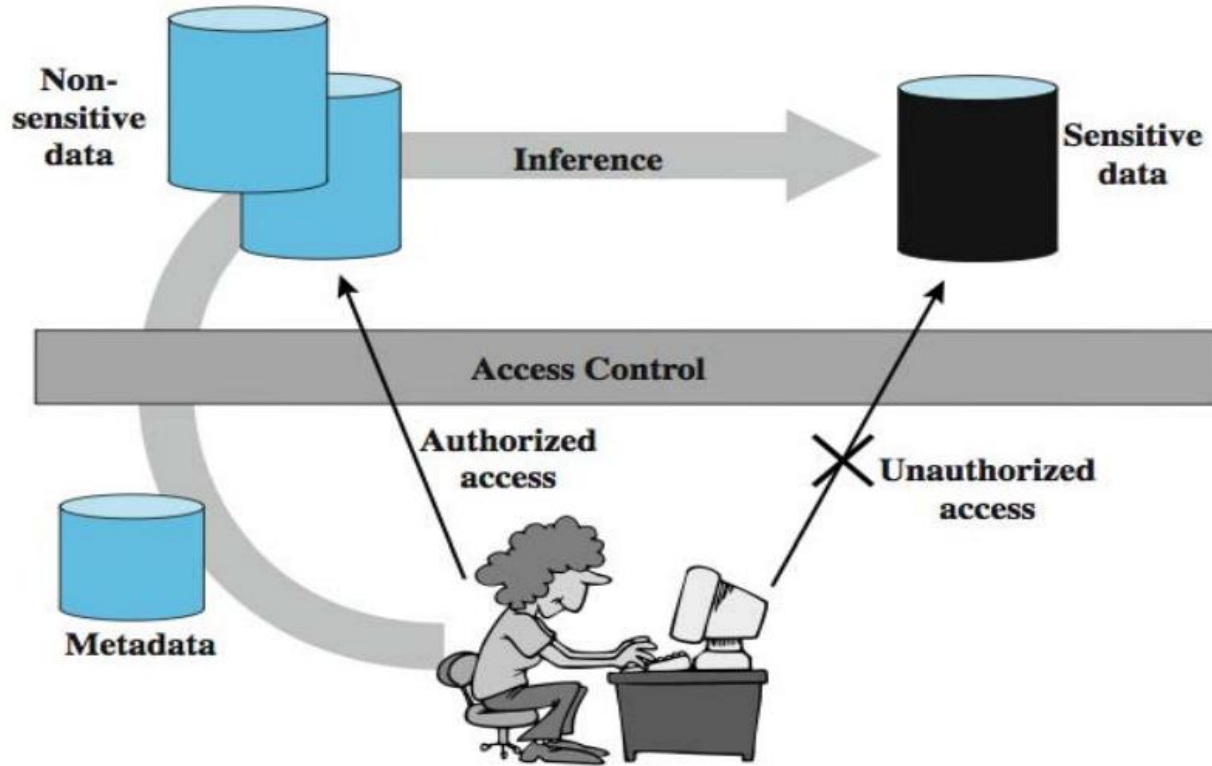
Public Listings

Public course rosters on LinkedIn can disclose academic performance and identify individuals who struggled.



Inference

means deriving sensitive data from non-sensitive data



Inference

Name	Position	Salary (\$)	Department	Dept. Manager
Andy	senior	43,000	strip	Cathy
Calvin	junior	35,000	strip	Cathy
Cathy	senior	48,000	strip	Cathy
Dennis	junior	38,000	panel	Herman
Herman	senior	55,000	panel	Herman
Ziggy	senior	67,000	panel	Herman

(a) Employee table

Position	Salary (\$)	Name	Department
senior	43,000	Andy	strip
junior	35,000	Calvin	strip
senior	48,000	Cathy	strip

(b) Two views

Name	Position	Salary (\$)	Department
Andy	senior	43,000	strip
Calvin	junior	35,000	strip
Cathy	senior	48,000	strip

(c) Table derived from combining query answers

Inference

1) Membership Inference on LLM API

- Initial: Adversary queries model with crafted prompts
- Act: Confidence/logit patterns reveal training presence
- Impact: Privacy breach for training participants
- Mitigate:
 - Differential privacy; limit confidences; output smoothing
 - Query rate limits; anomaly detection

2) Attribute Inference on Big Data Analytics

- Initial: Shared aggregated dashboards
- Act: Combine aggregates to reconstruct sensitive attributes
- Impact: Re-identification; policy/regulatory risk
- Mitigate:
 - k-anonymity/l-diversity; differential privacy
 - Query auditing; minimum cohort sizes

Intrusion



Problem 1

Weak credentials increase vulnerability to unauthorized access

Hacked accounts can lead to data breaches

Credential stuffing attacks Act weak passwords

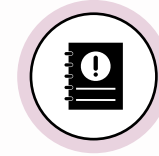


Problem 2

Exposed admin panels are prime targets for attackers

Unsecured access points attract malicious actors

Administrators unaware of potential Acts



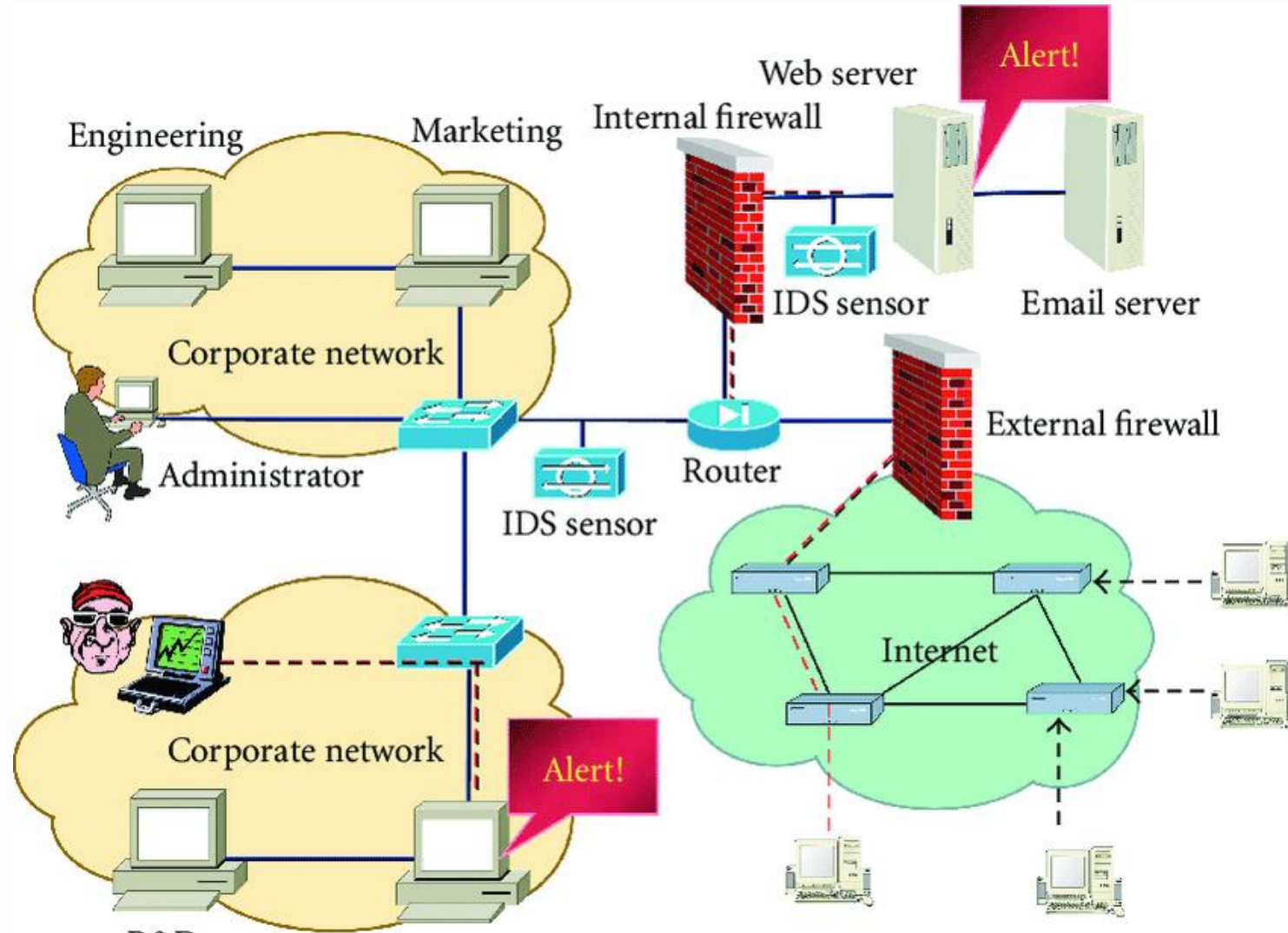
Problem 3

Unpatched services leave systems open to Actation

Known vulnerabilities allow easy attacks

Delay in updates can escalate risks

Intrusion



Intrusion

1) Compromised Service Account in Cloud Data Lake

- Initial: Stolen key from CI cache / dev laptop
- Act: Access lakehouse tables & export snapshots
- Impact: Mass data exfiltration
- Mitigate:
 - Workload identity (no long-lived keys)
 - Least-privilege; egress controls; behavior analytics

2) SSRF on Web App → Metadata Tokens → LLM Store

- Initial: SSRF hits cloud metadata endpoint
- Act: Retrieve temporary tokens; read model artifacts
- Impact: IP theft; privilege escalation
- Mitigate:
 - IMDSv2/metadata hop limits; SSRF defenses
 - VPC egress filters; per-resource IAM conditions

Unauthorized Disclosure Mitigations

Exposure

Implement Data Loss Prevention rules to prevent data breaches.

01

Interception

Use TLS encryption for securing data transmission channels.

02

Inference

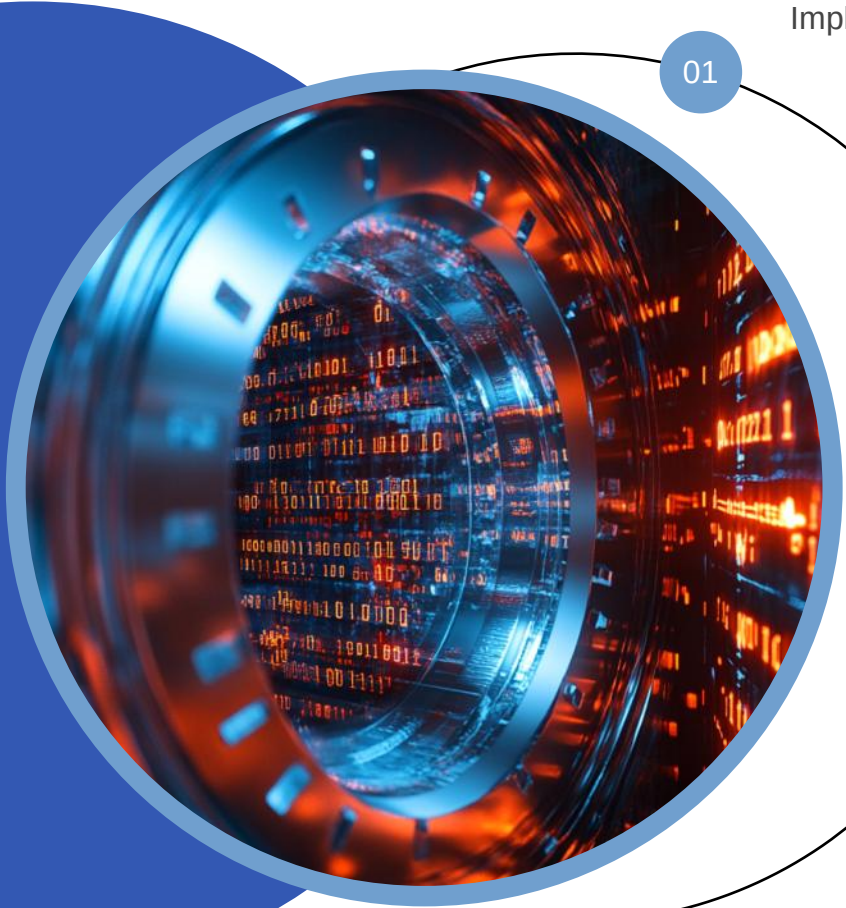
Limit metadata exposure to protect sensitive information availability.

03

Intrusion

Enforce multifactor authentication to prevent unauthorized access.

04



Mitigations for Unauthorized Disclosure



Data Loss Prevention

Utilize DLP solutions to prevent sensitive data leaks effectively.



File Classification

Classify files based on sensitivity to enhance protection measures.



MultiFactor Authentication

Enforce MFA for added security against unauthorized admissions.



Regular Audits

Conduct regular security audits to identify and address vulnerabilities.



Access Controls

Implement strict access controls for sensitive information repositories.



Secure Communications

Employ TLS to secure data in transit against unauthorized access.



Password Policies

Implement strong password policies to avoid default or weak credentials.



Education Programs

Provide awareness training for users on data protection practices.

Class Exercise - Unauthorized Disclosure

Find a real, reported cyber incident that matches the [Unauthorized Disclosure](#).

Deliverables

1. Incident title, organization/product (if public), and date.
2. Explain why it fits *this* category and sub-type.
3. Explain Attack Technology.
4. Assets & Data at Risk (Systems, data types, LLM model weights/keys/PII/etc).
5. Which of Confidentiality / Integrity / Availability were affected, and how?

Research: **10 min**

Present: **2–3 min** per team

2) Deception

RFC 2828 describes four kinds of threat consequences and kinds of attacks that result:

גלוי 1. Unauthorized disclosure

- חשיפה 1. Exposure
- יירוט 2. Interception
- הסקה 3. Inference
- התערבות 4. Intrusion

שיבוש 3. Disruption

- שליטת יכולת 1. Incapacitation
- השחתה 2. Corruption
- חסימה 3. Obstruction

הונאה 2. Deception

- התחזות 1. Masquerade
- זיוף 2. Falsification
- דחייה 3. Repudiation

תפיסה בלתי 4. Usurpation

- ניכוס פסול 1. Misappropriation
- שימוש לרעה 2. Misuse



2) Deception

הונאה

1.8.2 DECEPTION:

Is a threat to either system integrity or data integrity: it results in various attacks like:

התחזות

זיוף

דחייה

1. Masquerade: An unauthorized entity poses as an authorized entity.

2. Falsification: False data deceives an authorized entity.

3. Repudiation: An entity deceives another by falsely denying responsibility for an act.



Masquerade

01

Phishing Attack

Phishing targets users to steal sensitive authentication credentials.

02

Session Hijacking

Attackers gain control over user sessions for unauthorized actions.

03

Stolen Credentials

Compromised credentials used for impersonating trusted individuals.

04

API Key Theft

Acting stolen API keys to access restricted services.

05

Fake Requests

Using phished credentials to submit unauthorized modification requests.

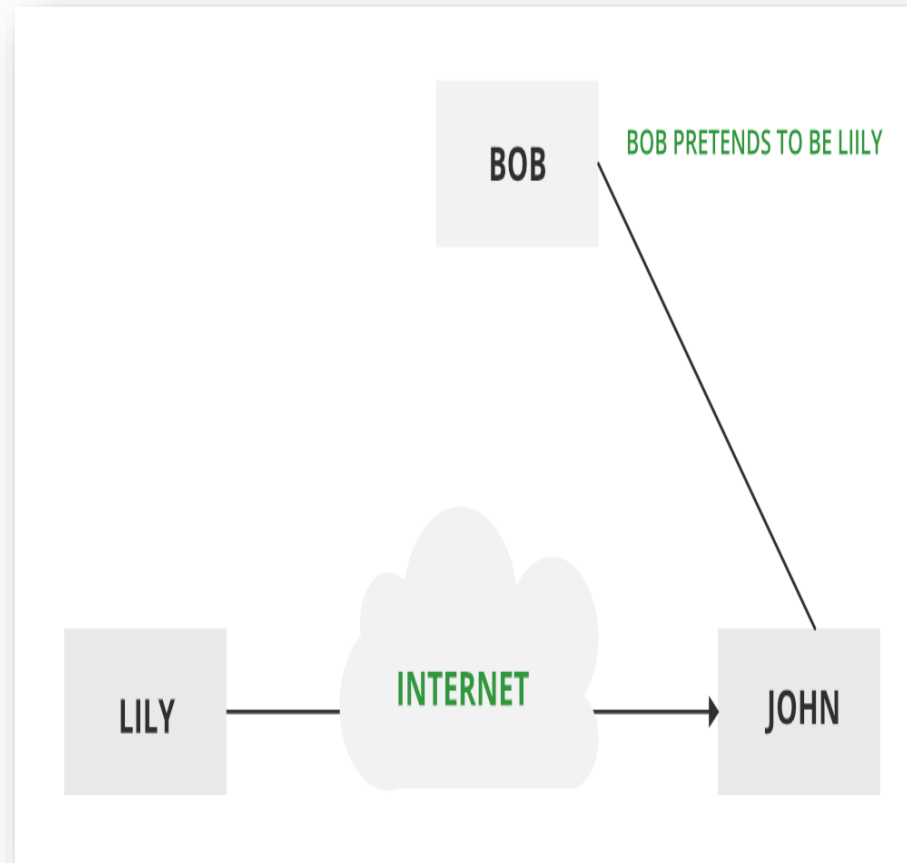
06

Social Engineering

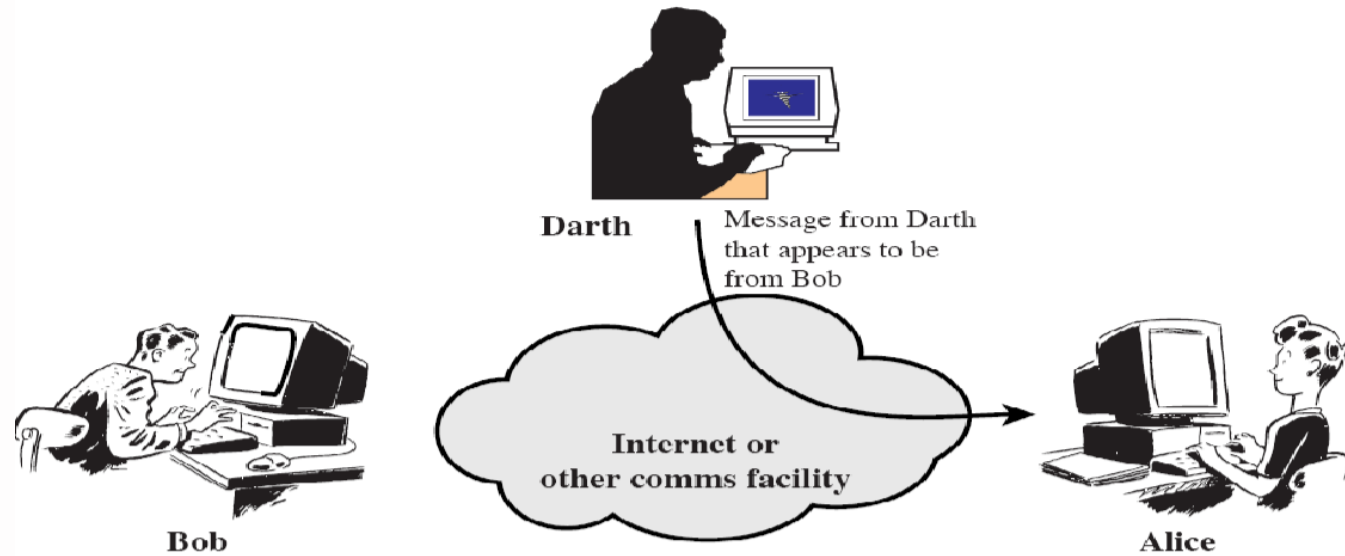
Manipulating users into sharing sensitive personal information.



Masquerade



Masquerade



Masquerade

1) Impersonation of LLM Service via Stolen API Key

- Initial: Key leaked in public repo / issue
- Act: Submit jobs as trusted service; access datasets
- Impact: Cost spike; data/IP exposure
- Mitigate:
 - Secret scanning; rotate keys; scopes & quotas
 - Prefer OAuth2/workload identity over static keys

2) OAuth Token Replay in Web SPA

- Initial: Token captured via XSS or log
- Act: Replay to masquerade user; call backend APIs
- Impact: Account takeover; data theft
- Mitigate:
 - Token binding; short-lived tokens; httpOnly cookies
 - CSP/XSS hardening; rotate on anomaly

Falsification

01

Data Manipulation

Cybercriminals frequently falsify data to mislead organizations. This manipulation can distort analytics and reporting, ultimately impacting business decisions and risk assessments.

02

Identity Theft

Falsification of identity is a common cyber threat where attackers impersonate legitimate users. This can grant unauthorized access to sensitive information, causing financial and reputational damage.

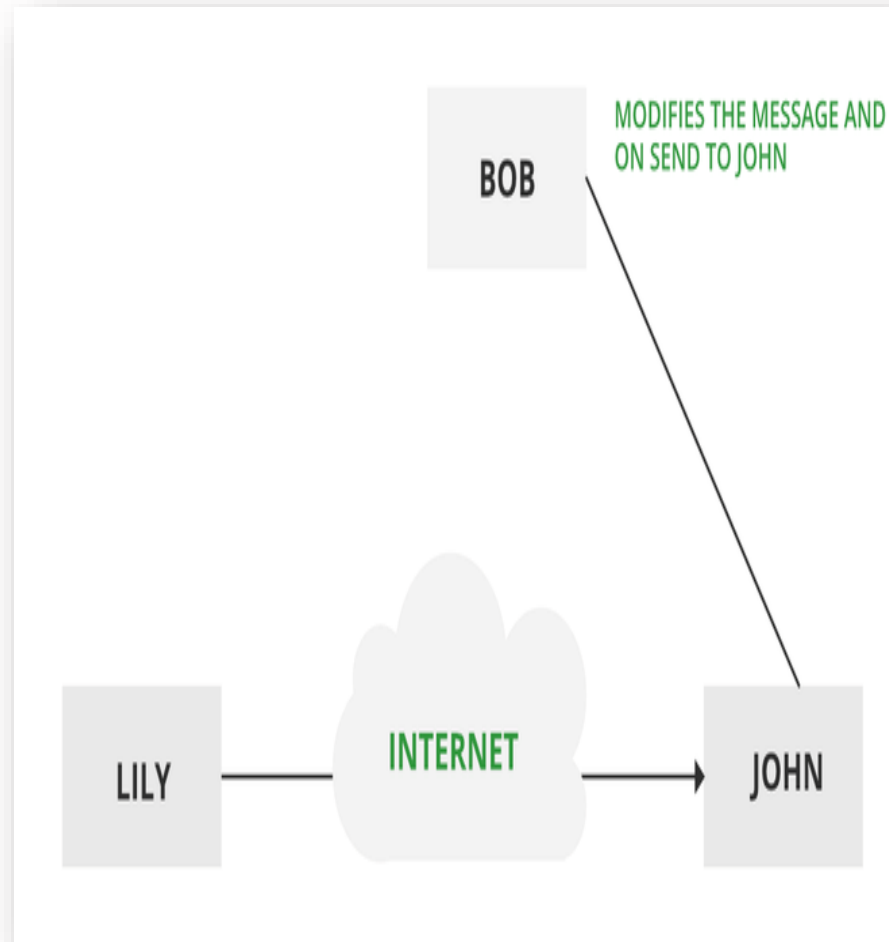
03

Credential Forgery

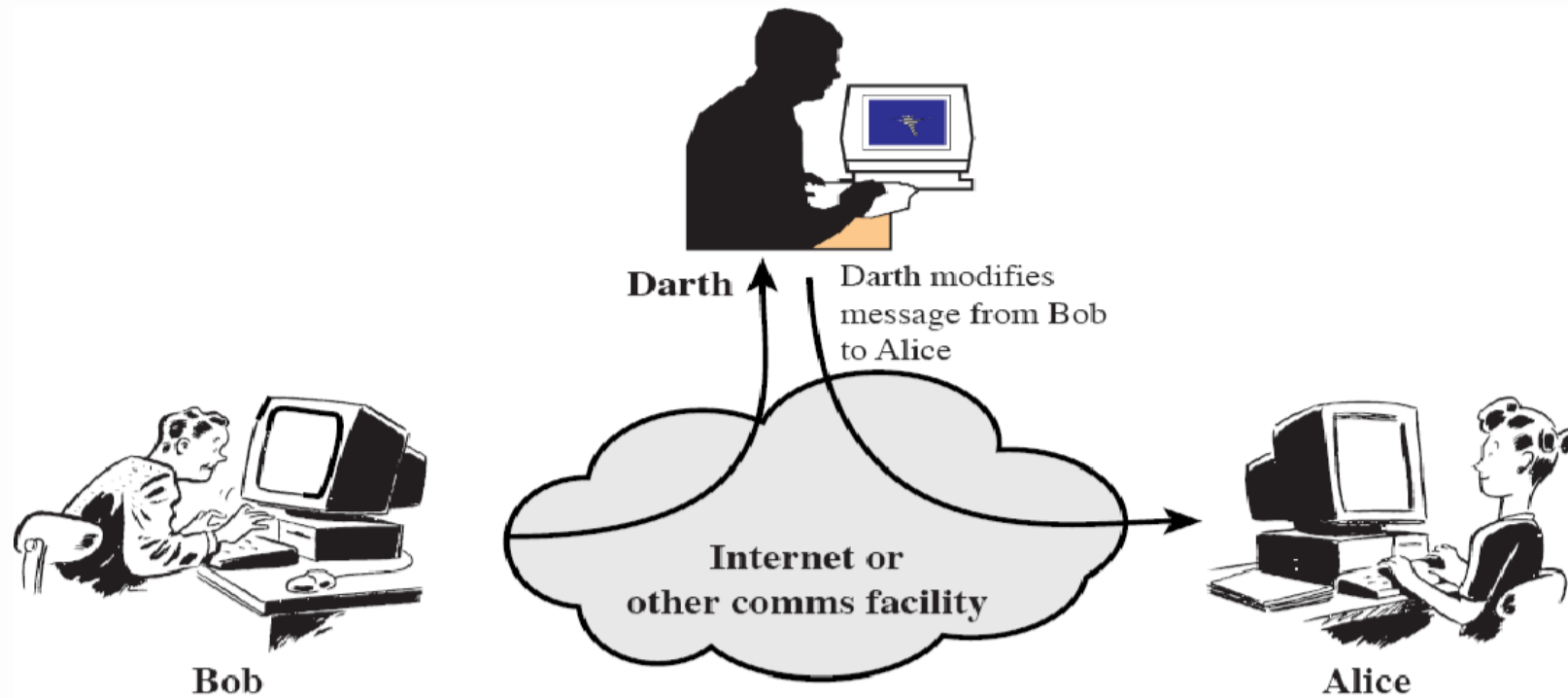
Cyber threats often involve the falsification of credentials to gain system access. Attackers Act weak file integrity controls to insert fake authentication tokens.



Falsification



Falsification



Falsification

1) Poisoned Prompt Tools (Fake Tool Response to Agent)

- Initial: Agent fetches tool output from compromised endpoint
- Act: Crafted JSON instructs agent to exfiltrate data
- Impact: Silent data loss; arbitrary actions
- Mitigate:
 - Signed tool responses; schema/intent validation
 - Allowlisted tools & domains; human review for risky ops

2) Data Forgery in Big Data Pipeline

- Initial: Weak producer auth on Kafka/Kinesis topic
- Act: Inject forged events → corrupt downstream analytics
- Impact: Bad business decisions; fraud
- Mitigate:
 - Producer authN/Z; message signing
 - Schema registry with compatibility checks; lineage tracing

Repudiation



Problem 1

Inadequate logging leads to unaccountability in cyber incidents

Missing logs create ambiguity in events

Alterable logs provide false narratives

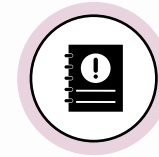


Problem 2

Denial of actions increases risk of untraceable threats

Party can refuse documented activities

Diminishes trust in security verification



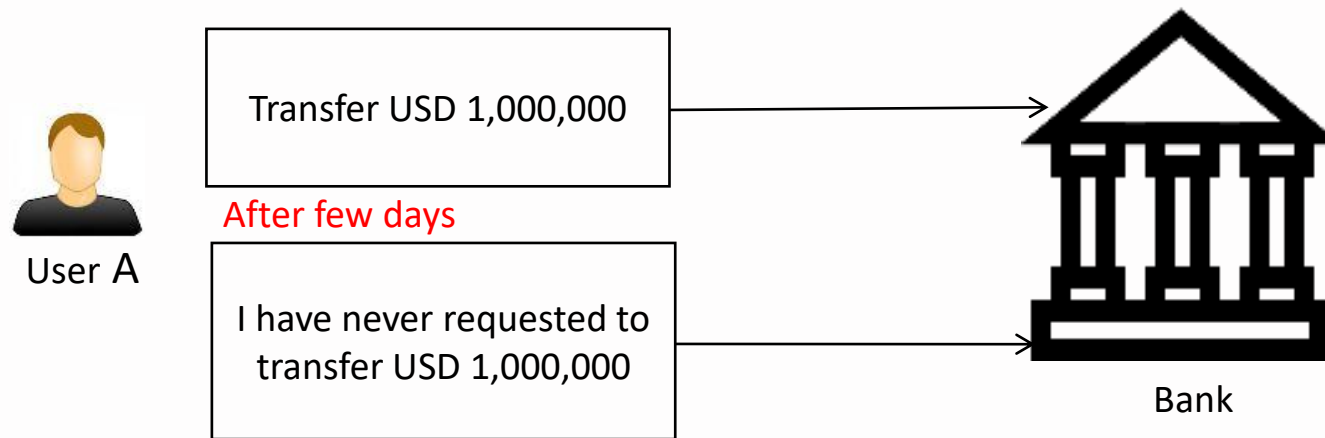
Problem 3

Challenges in meeting compliance and regulatory standards

Insufficient logs hinder forensic investigations

Difficulties in proving adherence to laws

Repudiation



Repudiation

1) No Tamper-Evident Audit on Model Deployment

- Initial: Manual changes without signed logs
- Act: Rollback/replace model; deny responsibility
- Impact: Forensics gaps; compliance issues
- Mitigate:
 - Append-only, signed audit; cryptographic timestamps
 - Change approvals; attested CI/CD

2) AI Agent Executes Payment Without Non-Repudiation

- Initial: Over-permissioned payment tool
- Act: Agent triggers transfer; user later disputes
- Impact: Financial loss; dispute risk
- Mitigate:
 - Per-action signing; step-up auth; HITL for high risk
 - Immutable logs; dual control

Deception in Cyber Threats



Masquerade

01

Implement MultiFactor Authentication to prevent unauthorized access through impersonation, ensuring that users verify their identity before accessing sensitive systems and data.

Implement multifactor authentication to prevent unauthorized access.

Falsification

02

Utilize strict data validation protocols to guard against falsification by confirming that incoming data meets established standards before acceptance into the system.

Use digital signatures to verify data integrity and authenticity.

Repudiation

03

Establish centralized logging systems with tamper-evident features to ensure all actions are recorded, enabling accountability and preventing repudiation of actions taken by users.

Establish tamper-evident logs to record and track all system actions.

Mitigation Strategies for Deception



Use MFA

Implement multifactor authentication to enhance user verification methods.



Track Activity

Maintain comprehensive logs of user activity to monitor for abnormalities.



Educate Users

Provide training on recognizing phishing attempts and social engineering tactics.



Secure Credentials

Enforce strong password policies and regular updates to user credentials.



Employ Digital Signatures

Use digital signatures to ensure data authenticity and integrity on documents.



Review Access

Conduct regular audits of user access rights for critical systems and data.



Implement Log Analysis

Utilize automated tools to analyze logs for signs of unauthorized activities.

Class Exercise - Deception

Find a real, reported cyber incident that matches the **Deception**.

Deliverables

1. Incident title, organization/product (if public), and date.
2. Explain why it fits *this* category and sub-type.
3. Explain Attack Technology.
4. Assets & Data at Risk (Systems, data types, LLM model weights/keys/PII/etc).
5. Which of Confidentiality / Integrity / Availability were affected, and how?

Research: **10 min**

Present: **2–3 min** per team

3) Disruption

RFC 2828 describes four kinds of threat consequences and kinds of attacks that result:

גלוי 1. Unauthorized disclosure

- חשיפה 1. Exposure
- יירוט 2. Interception
- הסקה 3. Inference
- התערבות 4. Intrusion

שיבוש 3. Disruption

- שליטת יכולת 1. Incapacitation
- השחתה 2. Corruption
- חסימה 3. Obstruction

הונאה 2. Deception

- התחזות 1. Masquerade
- זיוף 2. Falsification
- דחייה 3. Repudiation

תפיסה בלתי 4. Usurpation

- ניכוס פסול 1. Misappropriation
- שימוש לרעה 2. Misuse



3) Disruption

שיבוש

1.8.3 DISRUPTION:

Is a threat to availability or system integrity: it results in various attacks like:

שלילת יכולת

1. Incapacitation: Prevent/interrupt system operation by disabling a system component

השחתה

2. Corruption: adversely modifying system functions or data

חסימה

3. Obstruction: interrupts delivery of system services by hindering system operation.



Incapacitation

01

malicious downloads

Malware often infiltrates systems through phishing emails or malicious downloads, leading to significant data breaches and loss of sensitive information across various sectors.

02

Destructive Commands

Destructive commands can erase critical data or disrupt system functionality, making it essential for organizations to recognize the potential impact of unauthorized commands on their infrastructure.

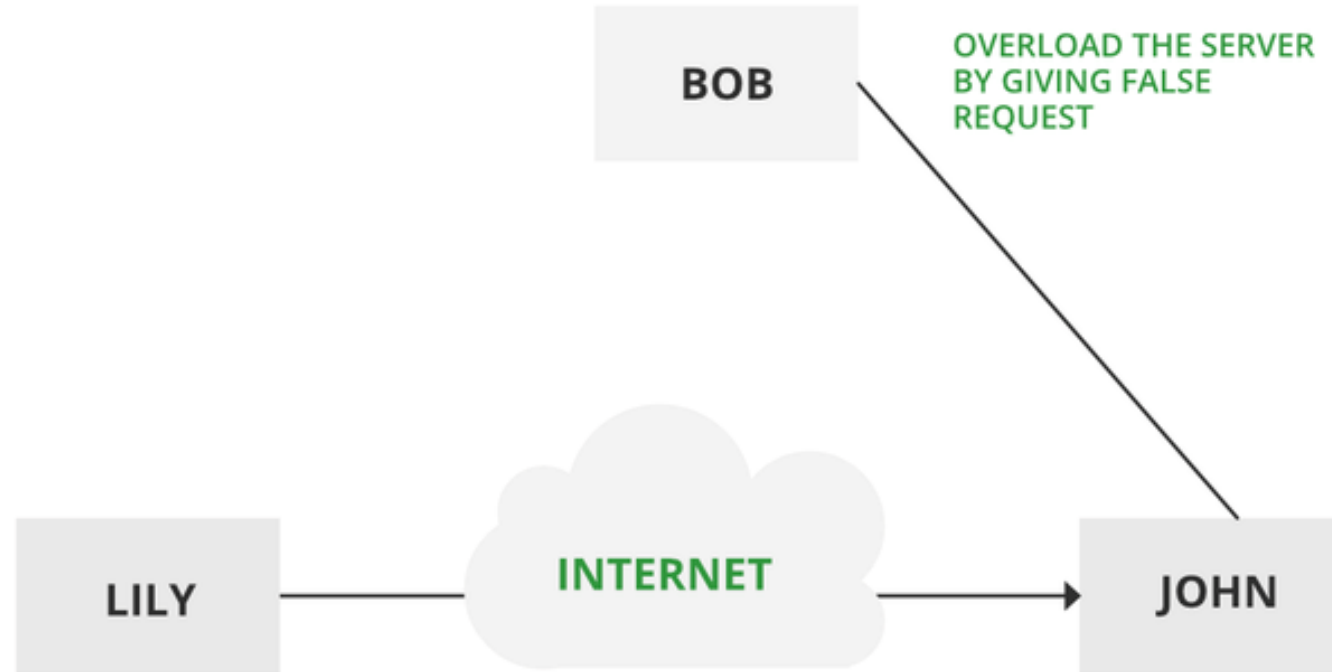
03

Hardware Failure

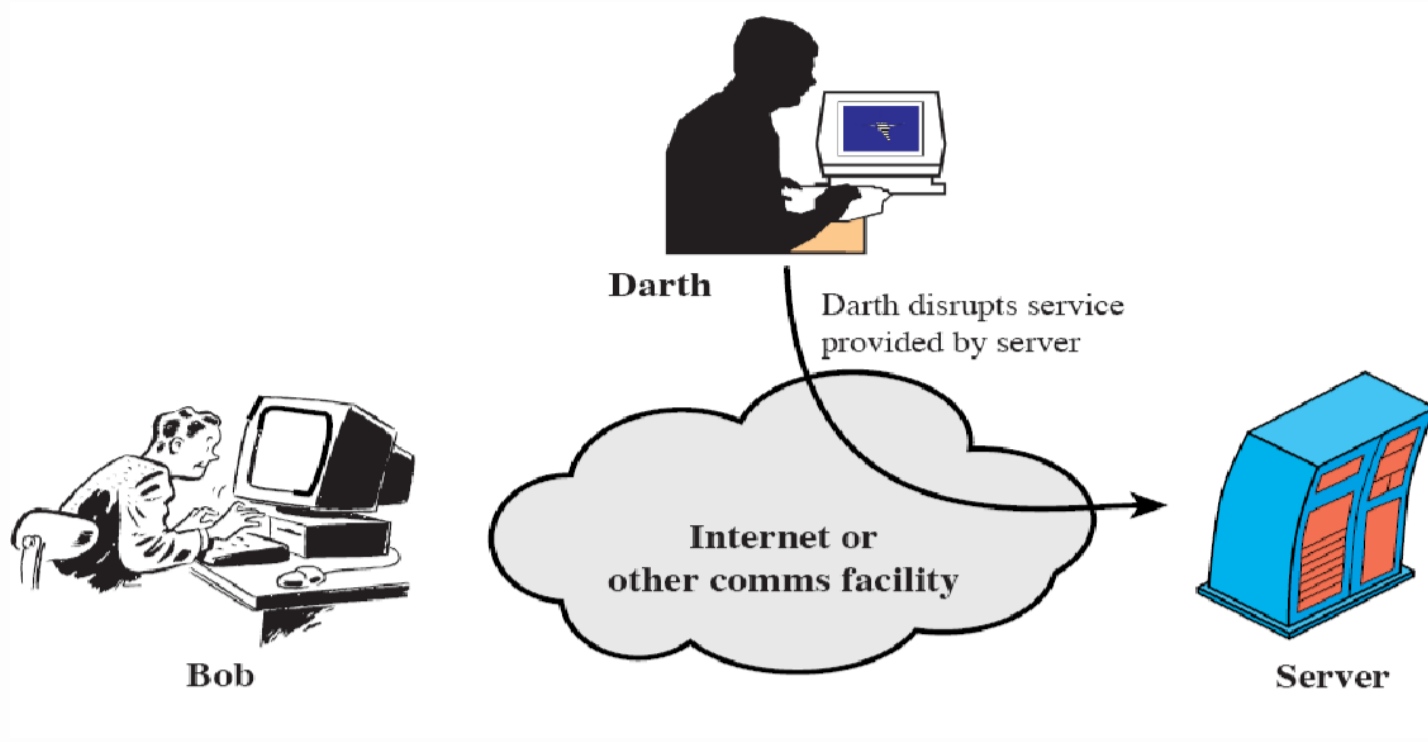
Unexpected hardware failures without redundancy can lead to irreversible data loss, emphasizing the importance of understanding vulnerabilities related to hardware integrity and reliability.



Incapacitation



Incapacitation



Incapacitation

1) Ransomware on Cloud Orchestrator Nodes

- Initial: Phish → access bastion / admin workstation
- Act: Encrypt cluster state & etcd backups
- Impact: Service outage; recovery delays
- Mitigate:
 - Isolated admin workstations; MFA; just-in-time admin
 - Offline backups; restore drills; immutable infra

2) Model Serving Capacity Exhaustion (Adversarial Load)

- Initial: Bot traffic sends expensive prompts
- Act: Saturate GPU inference pool
- Impact: Denial of service for legitimate users
- Mitigate:
 - Rate limiting; admission control; prompt cost caps
 - Priority queues; autoscaling with safeguards

Corruption

01

Faulty Updates

Unverified updates can introduce vulnerabilities and Acts into systems.

02

Unauthorized Writes

Malicious actors can alter data without appropriate permissions or checks.

03

Deserialization Bugs

Improper deserialization can lead to remote code execution and system compromise.



Corruption

1) Training Data Poisoning in LLM Pipeline

- Initial: Malicious samples injected in data lake
- Act: Bias or trigger model behavior
- Impact: Safety/accuracy degradation; backdoors
- Mitigate:
 - Signed datasets; data quality gates; outlier screening
 - Canary evals; reproducible training; rollback plans

2) Supply-Chain Tampering of Web NPM/PyPI Package

- Initial: Dependency hijack/typosquat
- Act: Build pulls backdoored lib → corrupt app
- Impact: Stealth data theft; downstream compromise
- Mitigate:
 - Lockfiles/SBOM; signature verification; provenance (SLSA)
 - Allowlist deps; renovate with policy checks

Obstruction

01

Volumetric Attacks

These attacks overload network bandwidth by sending massive amounts of data, disrupting services and affecting all connected devices and users within the network, leading to significant downtime.

02

Resource Exhaustion

Involves depleting the resources of a system, such as CPU or memory, leading to performance degradation. This can effectively immobilize critical systems and applications, resulting in operational failures.

03

Lock Contention

Occurs when multiple processes compete for the same resource, leading to delays and system crashes. This can be particularly damaging in database environments where data integrity is vital.



Obstruction

- 1) DDoS on API Gateway for Web/Agent Backends
 - Initial: Botnet floods AUTH/GraphQL endpoints
 - Act: Thread/conn exhaustion; cache busting
 - Impact: Latency spikes; outages
 - Mitigate:
 - CDN/WAF; rate limits; token bucket per-identity
 - Circuit breakers; graceful degradation; autoscale
- 2) Queue Backpressure in Big Data Stream
 - Initial: Sudden spike in events or slow consumer
 - Act: Fill partitions; block producers
 - Impact: Processing delays; SLA violations
 - Mitigate:
 - Autoscaling consumers; DLQs; backpressure policies
 - Partition rebalancing; flow control at producers

Disruption Mitigations

Incapacitation

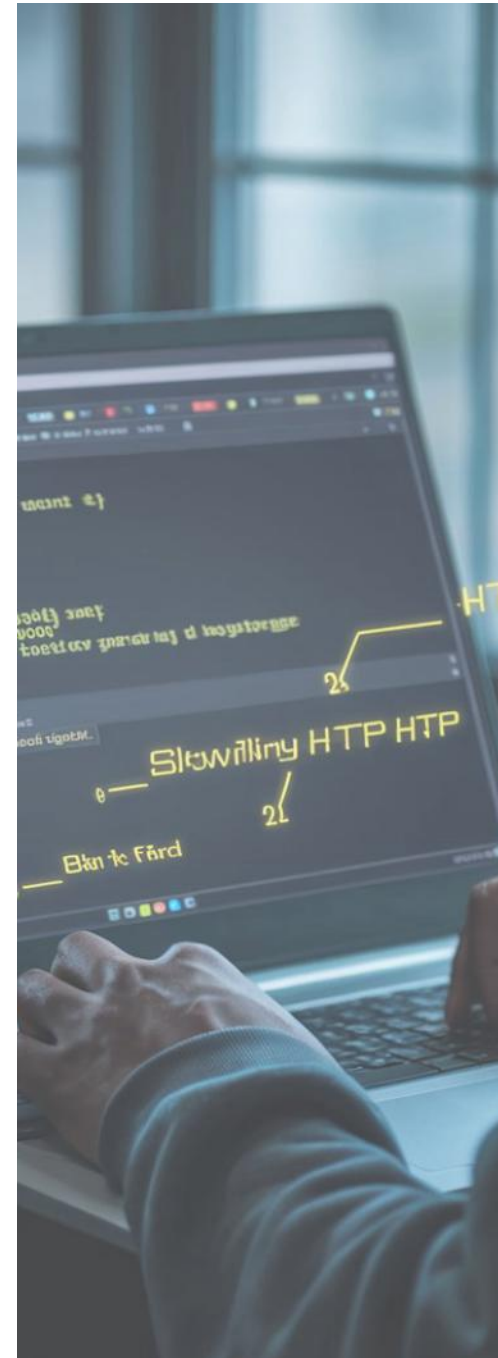
- 01 Implementing robust offline backups can help recover from ransomware attacks effectively and efficiently.

Corruption

- 02 Establishing regular backup schedules reduces risks related to data corruption caused by buggy scripts.

Obstruction

- 03 Utilizing ratelimiting mechanisms can mitigate the impact of DDoS attacks on legitimate user access.



Mitigating Disruption Threats



Backup

Maintain secure offline backups to restore compromised data easily.



Monitoring

Implement continuous monitoring to identify disruptions and respond quickly.



Ratelimiting

Apply ratelimiting to prevent overload and maintain system availability.



Firewalls

Employ Web Application Firewalls to safeguard against disruptive attacks.



Constraints

Establish strict constraints to prevent unauthorized data alterations.



Incident response

Develop an incident response plan to swiftly address disruption incidents.



Class Exercise - Disruption

Find a real, reported cyber incident that matches the **Disruption**.

Deliverables

1. Incident title, organization/product (if public), and date.
2. Explain why it fits *this* category and sub-type.
3. Explain Attack Technology.
4. Assets & Data at Risk (Systems, data types, LLM model weights/keys/PII/etc).
5. Which of Confidentiality / Integrity / Availability were affected, and how?

Research: **10 min**

Present: **2–3 min** per team

4) Usurpation

RFC 2828 describes four kinds of threat consequences and kinds of attacks that result:

גלוי 1. Unauthorized disclosure

- חשיפה 1. Exposure
- יירוט 2. Interception
- הסקה 3. Inference
- התערבות 4. Intrusion

שיבוש 3. Disruption

- שליטת יכולת 1. Incapacitation
- השחתה 2. Corruption
- חסימה 3. Obstruction

הונאה 2. Deception

- התחזות 1. Masquerade
- זיוף 2. Falsification
- דחייה 3. Repudiation

תפיסה בלתי 4. Usurpation

- ניכוס פסול 1. Misappropriation
- שימוש לרעה 2. Misuse



4) Usurpation

תפיסה בלח

1.8.4 USURPATION:

Is a threat to system integrity: it results in various attacks like:

ניכוס פסול

1. Misappropriation: unauthorized logical or physical control of a system resource.

שימוש לרעה

2. Misuse: Causes system to perform a function or service detrimental to security.



Misappropriation

Insider Access

01

Internal personnel can Act access to sensitive information for personal gain or malicious intent.

Weak IP Controls

02

Failure to enforce intellectual property restrictions leads to theft and unauthorized sharing of vital data.

Overbroad Permissions

03

Excessive permissions granted to users increase the risk of information leakage or unauthorized use.



Misappropriation

1) Model Weights Exfiltration from Artifact Registry

- Initial: Over-broad IAM on registry
- Act: Dump proprietary checkpoints
- Impact: IP theft; competitive loss
- Mitigate:
 - Repo encryption; per-project IAM; access reviews
 - Watermarking; egress monitoring for large pulls

2) Cloud Credit Abuse via Compromised Keys

- Initial: Keys leaked; attacker spins GPU clusters
- Act: Crypto mining or model training on your dime
- Impact: Massive cost; quota exhaustion
- Mitigate:
 - Keyless auth; org quotas; spend alerts
 - JIT permissions; anomaly-based cost guardrails

Misuse

01

Privilege Abuse

Actuation of excessive access for unauthorized actions.

02

Monitoring Gaps

Insufficient tracking leads to unnoticed malicious activities.

03

Data Leakage

Sensitive information at risk through misuse of privileges.

04

Hospitality Risks

Shared credentials may facilitate unauthorized network access.

05

Quota Violations

Exceeding limits can indicate compromised accounts or resources.

06

Account Hijacking

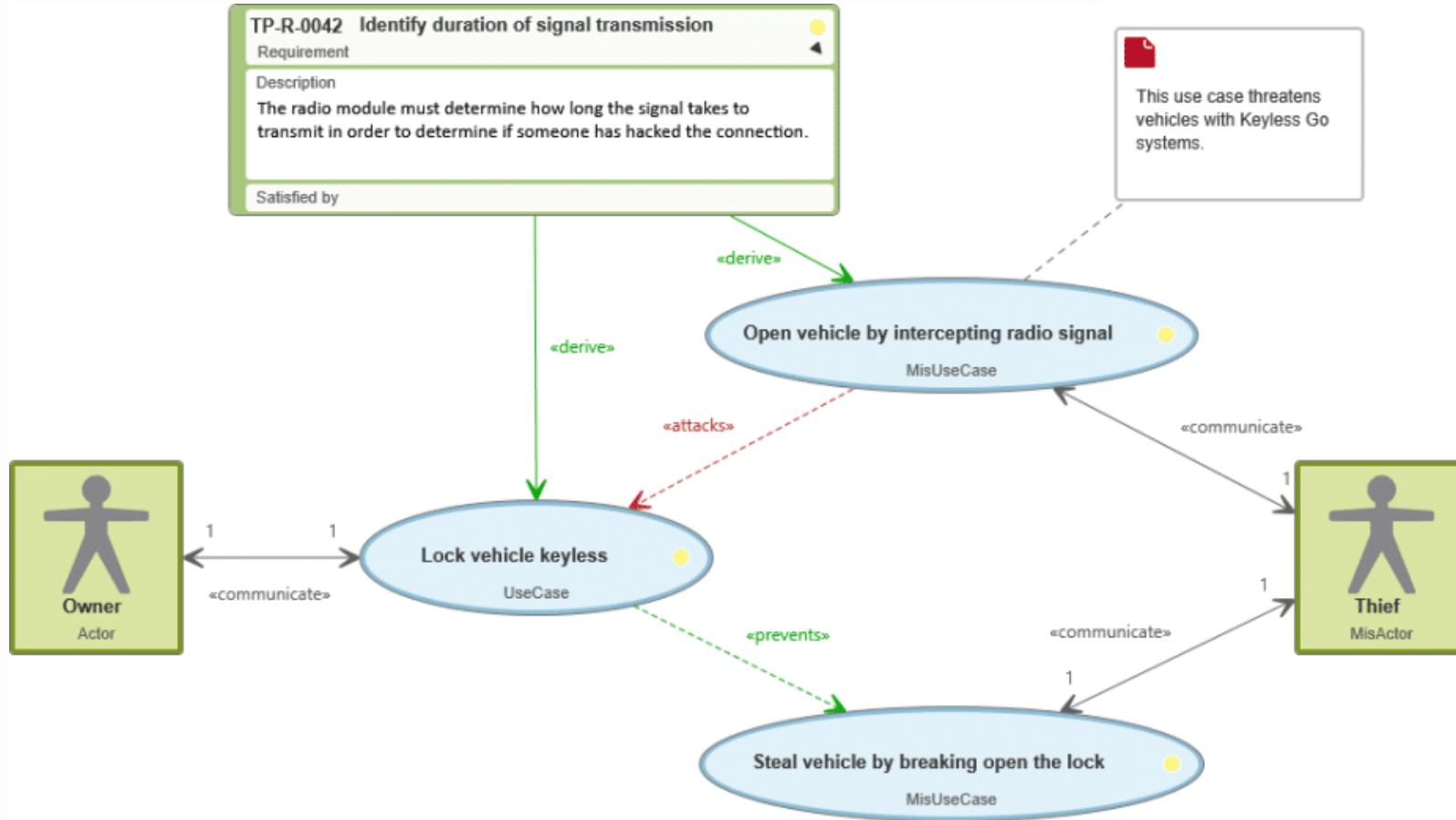
Stolen credentials allow attackers to impersonate users easily.



Misuse



Misuse



Misuse

- 1) AI Agent with Overbroad Tools Performs Dangerous Actions
 - • Initial: Agent can run shell/db/payment without constraints
 - • Exploit: Prompt injection triggers destructive queries
 - • Impact: Data loss; fraud; outages
 - Mitigate:
 - - Capability-scoped tools; sandboxing; intent validation
 - - HITL for high-risk; policy-as-code guardrails
- 2) Abusing Admin Console in Web SaaS
 - • Initial: Privileged account lacks MFA & approvals
 - • Exploit: Bulk export users/data; disable security policies
 - • Impact: Compliance breach; trust damage
 - Mitigate:
 - - MFA; just-in-time elevation; least privilege
 - - Immutable audit; break-glass with alerts

Usurpation Mitigations



Misappropriation

01

Ensure strict access controls to prevent unauthorized individuals from gaining control over sensitive assets and data, particularly in research and proprietary environments.

Misuse

02

Implement comprehensive auditing and monitoring systems to identify and deter any inappropriate usage of assets or information by insiders, protecting organizational integrity.

Mitigation Techniques for Usurpation



Leastprivilege

Grant users the minimum access necessary for tasks.



Access logging

Implement comprehensive logging to track user activities.



Regular audits

Conduct routine assessments of access and usage.



Digital Rights

Utilize digital rights management to control asset access.



Anomaly detection

Deploy systems to identify unusual activity patterns.



Awareness training

Educate users about the risks of unauthorized access.



Class Exercise - Usurpation

Find a real, reported cyber incident that matches the **Disruption**.

Deliverables

1. Incident title, organization/product (if public), and date.
2. Explain why it fits *this* category and sub-type.
3. Explain Attack Technology.
4. Assets & Data at Risk (Systems, data types, LLM model weights/keys/PII/etc).
5. Which of Confidentiality / Integrity / Availability were affected, and how?

Research: **10 min**

Present: **2–3 min** per team

Mapping Threats to CIA Principles

	Confidentiality	Integrity	Availability	Accountability
Unauthorized Disclosure	High	Low	Medium	High
Deception	Medium	High	Medium	High
Disruption	Medium	Low	High	Low
Usurpation	High	Medium	Low	Medium